

AgentShield: Knowledge Transfer & Glossary

Internal Team Study Guide for Mid-Sem Review

1. Core Architecture Concepts

Model Context Protocol (MCP):

An open standard created by Anthropic that allows AI models (like Claude) to securely connect to external tools, databases, and APIs. Think of it as a universal plug that gives AI hands to interact with local enterprise systems.

JSON-RPC 2.0:

A Remote Procedure Call protocol encoded in JSON. It is the language that the AI and the MCP server use to talk to each other. It contains a 'method' (what to do) and 'params' (the arguments).

Transparent Proxy:

A server that sits in the middle of a connection without modifying the sender or receiver. In our project, the AI thinks it's talking to the target server, and the target server thinks it's talking to the AI. Neither knows AgentShield is secretly in the middle inspecting the traffic.

Asynchronous (Async/Await) & FastAPI:

Modern Python frameworks (like FastAPI) use 'async' to avoid freezing. When our proxy pauses a request to wait for human approval, it doesn't freeze the whole server. It efficiently puts that single request to sleep while continuing to serve other AI requests.

2. Inbound Security (The Risk Engine)

Prompt Injection / DAN Jailbreak:

A cyberattack where a user tricks the AI by injecting malicious instructions (e.g., 'Ignore all previous rules' or 'Do Anything Now (DAN)'). Our proxy scans for these and blocks them before they reach the enterprise system.

SQLi (SQL Injection):

An attack where malicious SQL statements are inserted into an input field (e.g., 'DROP TABLE users'). Our proxy detects these in the tool arguments.

Regex (Regular Expressions):

A sequence of characters that specifies a search pattern. We use Regex to look for exact malicious shapes (like '<system_override>') in the AI's payload.

Heuristics (Wildcards):

Instead of looking for exact strings, heuristics use logic/rules of thumb. For example, instead of blocking the exact tool 'github_delete_repo', our heuristic engine flags ANY tool containing the wildcard word 'delete', 'drop', or 'remove'.

Human-in-the-Loop (HITL):

A security mechanism where an automated process pauses a high-risk action (like deleting a database) and holds it in

AgentShield: Knowledge Transfer & Glossary

Internal Team Study Guide for Mid-Sem Review

memory until a human administrator clicks 'Approve' or 'Deny'.

AgentShield: Knowledge Transfer & Glossary

Internal Team Study Guide for Mid-Sem Review

3. Outbound Security (The Sanitizer)

PII (Personally Identifiable Information):

Highly sensitive user data that can identify a specific person or compromise security (e.g., Aadhaar Numbers, PAN Cards, AWS API Keys, Passwords).

Recursive JSON Sanitization:

When the MCP server returns a response, it might be deeply nested (a dictionary inside a list inside a dictionary). Our 'recursive' algorithm crawls down into every single layer of the JSON to ensure no PII is hiding anywhere, replacing it with '[REDACTED]'.

Data Exfiltration:

The unauthorized transfer or theft of data. By scrubbing PII, we prevent a hacked AI from exfiltrating sensitive enterprise data back to the attacker.

4. Testing & QA Terminologies

PyTest:

A robust Python testing framework used to write and run automated test code.

Integration Testing:

Testing the entire system working together (e.g., the AI, the Proxy, and the Target MCP). This proves that our proxy doesn't accidentally break or corrupt the JSON-RPC traffic when it forwards it.

Enterprise Schema Mocking:

We created fake (mock) versions of 15 real-world corporate MCP servers (like GitHub or PostgreSQL). We tested our proxy against these fake servers to scientifically prove it works on real-world enterprise data structures.